

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 3 – INCIDENT RESPONSE (MONITORING & MITIGATION)

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 3
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Develop Incident Response Plan, Analyze Security Monitoring Dashboard, Recommend Mitigation Strategies and Technical Justification.		
Student Name:	Syed Saniya Iqbal	Reg. No.:	192465043
Section / Batch:	CSE-Cybersecurity	Date:	27/08/2026

Instructions to Students

- Develop an incident response plan based on the given security incident scenario and identified findings.
- Analyze the provided security monitoring dashboard, alerts, logs and indicators to determine incident status and affected assets.
- Recommend prioritized mitigation strategies that directly address the identified threats, vulnerabilities and incident impact.
- Provide clear technical justification for each major response and mitigation decision using evidence from the scenario.
- Present the response plan, dashboard analysis and recommendations clearly and professionally within the prescribed submission format.

Question Type	Focus Area	Questions	Marks
INCIDENT RESPONSE	Monitoring & Mitigation	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

1. Incident Scenario and Dashboard Analysis

The security monitoring dashboard indicates a significant increase in account-takeover alerts together with a high number of automated login attempts. The combination suggests an active authentication-abuse campaign. The most likely techniques are credential stuffing, password spraying, bot-driven login attempts, and use of rotating IP addresses or proxy infrastructure.

Dashboard Indicator	Interpretation	Risk	Required Action
Increase in account-takeover alerts	More accounts are showing behavior associated with unauthorized access.	Critical	Identify affected accounts and correlate events.
High automated login volume	Login traffic is likely generated by scripts/bots rather than normal users.	High	Activate bot controls and rate limits.
Repeated failed logins	Possible credential stuffing or password spraying.	High	Throttle attempts and monitor account/IP velocity.
Successful login after many failures	Possible valid credential compromise.	Critical	Trigger step-up MFA and investigate the session.
Unusual IP/device/location patterns	Possible proxy use, new devices, or attacker infrastructure.	High	Apply risk-based authentication and reputation checks.

2. Incident Classification and Risk Assessment

This incident should be treated as a high-priority authentication security incident because successful account takeover can lead to privacy violations, impersonation, malicious posts/messages, financial abuse, loss of user trust, and compromise of connected services.

Threat	Likelihood	Impact	Risk Level	Reason
Credential stuffing	High	Critical	Critical	Stolen credentials can produce direct account compromise.
Bot-driven login attempts	High	High	High	Automation enables attackers to test credentials at scale.
Password spraying	Medium-High	High	High	A small password set may be tested across many accounts.

Session/token abuse	Medium	Critical	High	Compromised sessions can bypass normal password controls.
Authentication service overload	Medium	Medium–High	High	Large request volumes can degrade login availability.

3. Incident Response Plan

Phase 1 – Preparation

Maintain centralized authentication logs, dashboards, alert thresholds, incident contacts, account-recovery procedures, and tested playbooks. Ensure responders can revoke sessions, disable accounts, force password resets, and enforce MFA.

Phase 2 – Detection and Analysis

Correlate login failures and successes by account, source IP, ASN, device fingerprint, location, user agent, time, and authentication method. Look for high request velocity, distributed attempts, unusual locations, new devices, and successful logins immediately following failure bursts.

Phase 3 – Containment

Apply temporary rate limits, bot challenges, IP/network controls, and risk-based step-up authentication. Protect high-value accounts first. Lock or restrict confirmed compromised accounts and revoke active sessions/tokens. Preserve logs before making changes that could destroy evidence.

Phase 4 – Eradication

Remove attacker persistence, including unauthorized sessions, recovery-setting changes, malicious application access, and stolen authentication artifacts. Force password resets for affected users and block confirmed malicious infrastructure.

Phase 5 – Recovery

Restore accounts using verified recovery procedures. Require MFA re-verification, monitor recovered accounts, and gradually remove temporary restrictions only after attack indicators return to normal.

Phase 6 – Lessons Learned

Create a final incident timeline, identify control failures, measure response time and false positives, tune detection rules, and update the incident-response playbook.

4. Mitigation Strategies

Multi-Factor Authentication (MFA)

MFA adds an independent authentication factor such as a passkey, authenticator application, or hardware security key. It is justified because a stolen password alone should not provide access to the account. MFA therefore reduces the success rate of credential-stuffing and password-theft attacks. It should be mandatory for administrators and progressively enforced for all users, especially high-risk accounts.

Rate Limiting

Rate limiting restricts how frequently authentication requests can be made. It directly addresses automated login attempts because attackers depend on high request volume. Limits should be applied by account, IP, device, network/ASN, and risk level rather than relying on only one dimension. Adaptive limits can reduce the chance of attackers bypassing a simple IP-only rule.

Risk-Based Authentication (RBA)

RBA assigns a risk level to each login using signals such as device familiarity, location, IP reputation, login velocity, behavior, and historical patterns. Low-risk users can authenticate normally, while high-risk attempts can be challenged with MFA or blocked. This provides stronger protection without adding unnecessary friction to every legitimate login.

Bot Detection

Bot detection identifies automated behavior using request frequency, browser/device signals, behavioral patterns, reputation, and challenge mechanisms. It is essential because the dashboard specifically shows automated login activity. Detecting bots at the edge or authentication gateway reduces malicious traffic before it consumes application resources or reaches the login system.

5. Layered Security Architecture

1. Internet / User Requests
2. CDN / WAF / Bot-Management Layer – filter obvious automation and malicious traffic.
3. Rate-Limiting Layer – throttle excessive authentication attempts using account, IP, device, and network signals.
4. Risk Engine – calculate login risk from device, location, reputation, velocity, and behavior.
5. Authentication Service – password verification plus MFA/step-up challenge where required.
6. Session Management – issue secure sessions and revoke them when compromise is detected.
7. Security Monitoring / SIEM – correlate events and generate account-takeover alerts.
8. Incident Response Team – investigate, contain, recover, and improve controls.

6. Evidence and Log Collection

- Authentication logs containing timestamps, account identifiers, success/failure status, source IP, response codes, and authentication method.
- Device/browser information, user-agent strings, session identifiers, and device-fingerprint changes.
- IP, ASN, geolocation, proxy/VPN reputation, and network-level indicators where appropriate.
- Bot-management, WAF, CAPTCHA/challenge, and rate-limit events.
- MFA enrollment and challenge results, password-reset events, recovery-setting changes, and session/token revocations.
- Post-login activity such as profile changes, unusual messaging, unauthorized posts, bulk actions, or suspicious API usage.

7. Response Decision Matrix

Condition	Risk	Automated Response	Analyst Action
Normal device + normal behavior	Low	Allow login	Routine monitoring

New device but normal behavior	Medium	Request MFA	Verify if repeated
High login velocity / suspicious IP	High	Rate limit + challenge	Investigate source and scope
Successful login after attack pattern	Critical	Step-up MFA + revoke suspicious sessions if needed	Investigate account immediately
Confirmed takeover indicators	Critical	Lock/restrict account + revoke sessions	Reset credentials and recover account

8. Monitoring and Success Metrics

- Mean Time to Detect (MTTD) and Mean Time to Contain (MTTC).
- Number and percentage of successful account-takeover events.
- Volume of automated login requests blocked or challenged.
- Percentage of users and privileged accounts protected by MFA.
- False-positive rate for risk-based authentication challenges.
- Number of suspicious successful logins detected after abnormal failure bursts.
- Authentication-service availability and latency during attack periods.
- Percentage of compromised accounts with sessions revoked within the response target.

9. Prioritized Recommendations

Immediate – P0: Activate bot detection and adaptive rate limiting; identify confirmed compromised accounts; revoke suspicious sessions; enforce step-up MFA; preserve evidence.

Short Term – P1: Expand MFA coverage, implement risk-based authentication, strengthen compromised-password detection, and improve dashboard correlation across account/device/IP dimensions.

Medium Term – P2: Deploy continuous behavioral monitoring, tune detection models, test incident-response procedures, and establish attack-specific thresholds and playbooks.

Long Term – P3: Adopt a layered identity-security architecture with continuous authentication, strong session management, centralized security analytics, and regular control validation.

10. Technical Justification Summary

No single control is sufficient against account takeover. MFA protects against stolen passwords; rate limiting reduces the speed and scale of credential attacks; risk-based authentication adds context and applies stronger controls when behavior is suspicious; and bot detection identifies and disrupts automated activity. When these controls are combined with centralized monitoring, session revocation, secure recovery, and incident response, the organization obtains defense in depth.

11. Conclusion

The social-media dashboard indicates a high-priority authentication threat characterized by account-takeover alerts and automated login attempts. The recommended response is to detect and correlate the attack, contain it with rate limiting and bot controls, protect users through MFA and risk-based authentication, eradicate unauthorized sessions and credentials, and recover accounts under close monitoring. The layered approach reduces both the probability of successful takeover and the operational impact of large-scale automated attacks.